



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Threat and risk analysis models

Michele Colajanni

Dipartimento di Informatica – Scienza e Ingegneria
michele.colajanni@unibo.it

Fundamental principles

- 1) **Threat and risk analysis models:** “who the attacker is, what they want, and what the attack surfaces are” remains the same, regardless of the technology.
- 2) **Fundamental vulnerability classes:** *user-related vulnerabilities*, *software-related vulnerabilities* (buffer overflows, code injection, race conditions, memory management issues) remain the same. The languages in which they manifest may change, but the underlying logic does not. The same for *system* and *management vulnerabilities*.
- 3) **Cryptography, its mathematical primitives (RSA, elliptic curves, hashes), and associated protocols:** implementations change, but the underlying theory does not. [With the exception of *quantum-safe cryptography*.]
- 4) **Secure design principles:** **least privilege**, **strong authentication**, **defense-in-depth**, and **fail-safe defaults** (explicit permissions rather than default ones) remain perfectly valid in any architecture.

Meaning

CYBERSECURITY is related to the defense of the **CYBERSPACE**

It is larger than (and includes)

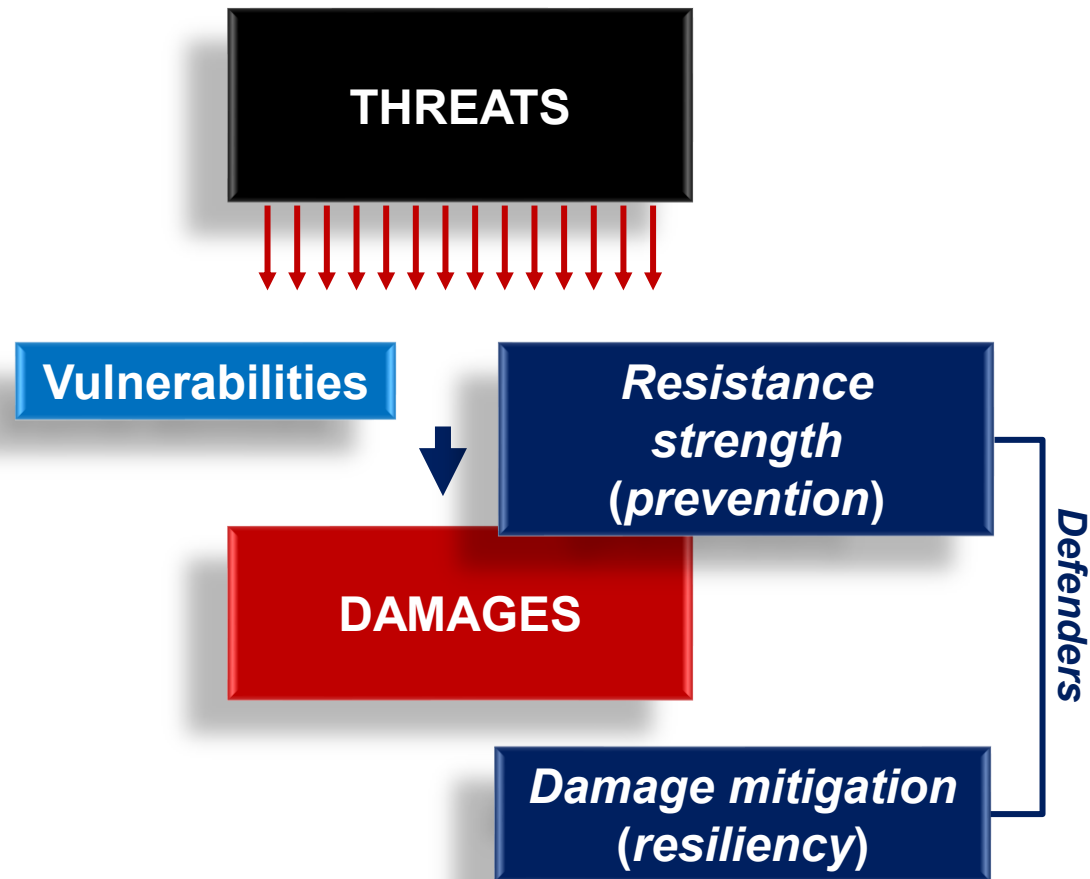
- IT security
- Logical security
- Information security
- Privacy

It is different from

- **Physical security**, although in some instances they can merge, and the methodologic approach is similar
- **Safety**, although one day ...



Cyber risk management and the Roles of defenders



Threat types



INTENTIONAL ACTION

External attacks

Supply chain attacks

Internal attacks

NEGLIGENT ACTION

Human errors

INTERNAL ACCIDENTAL EVENT

Failures

Incidents



EXTERNAL ACCIDENTAL EVENT

Natural disasters

Changes in Law

Changes in market rules

Technological innovations

SUPPLIER ACCIDENTAL EVENT

Failures

Incidents



Cyber threat types are human-based



INTENTIONAL ACTION

External attacks

Supply chain attacks

Internal attacks

NEGLIGENT ACTION

Human errors

INTERNAL ACCIDENTAL EVENT

Failures

Incidents

SUPPLIER ACCIDENTAL EVENT

Failures

Incidents

EXTERNAL ACCIDENTAL EVENT

Natural disasters

Changes in Law

Changes in market rules

Technological innovations



Top cyber threats are human, today supported by AI

There is always a human or a crew of humans behind a cyber **attack**. They study your vulnerabilities and your defenses to find the most *appropriate* attacks →

Their attacks are **adaptive**; hence any **static** defense will fail

Two false stereotypes:

- They do not wear caps when they attack
- Regardless of what journalists say, we do not call them **hackers** (their “crime” is just curiosity), but we prefer **attackers**, **criminals**, **adversaries**, **malicious actors**, **threat actors**, etc.



~~HACKER~~



Main damages (yesterday)



+



Main damages (*today*)



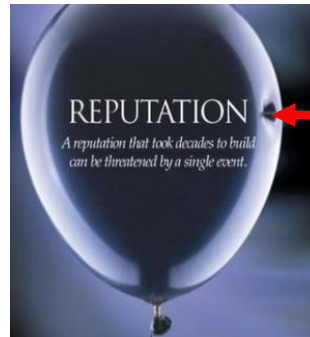
+



+



+



+



Cyber threat actors and motivations



[96%]



[4%]



Cyber threat actors and motivations



[96%]

[4%]

Nation State Actors

Advanced Persistent Threats

Criminals

Professionals

Specialized companies

Ideology

Hacktivists

Terrorists

Antagonists

Lamer

Script kiddies

Pathology



Cyber threat actors and motivations



[96%]



[4%]

Ideology

Hacktivists

Terrorists

Antagonists

Lamer

Script kiddies

If the company does not fall into specific categories, they do not represent a likely cyber threat

Pathology



Cyber threat actors and pathological motivations



[96%]



[4%]

Ideology

Hacktivists

Terrorists

Antagonists

Lamer

Script kiddies

- Sexual harassment
- Stalking
- Soliciting
- Child-pornography
- Cyberbullying
- Revenge porn
- Personal threats
- Slander
- Troll
- Theft of personal information
- Privacy violation

Pathology



Cyber threat actors and motivations



[96%]



Ideology

Pathology

Script kiddies

People, often young, with a lot of time, who are not IT experts. They download attack tools (*scripts*) and test them against typically random companies looking for vulnerabilities for enter the computer system, deface or block the website, violate login credentials. The initial goal is not to get rich but to impress friends or groups of people dedicated to the same goals



Script kiddies and possible evolution

Not being (initially) experts does not make script kiddies any less dangerous as they can cause multiple harm to unprotected companies



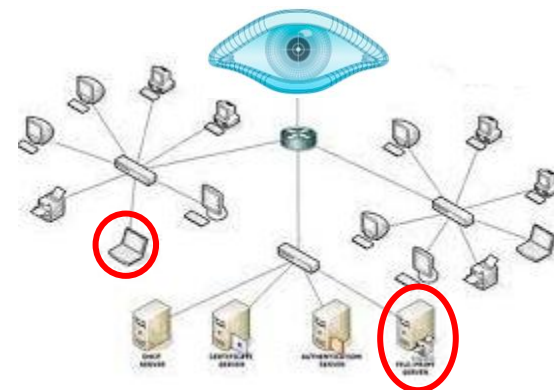
Possible evolutions

- They can be targeted and hooked by more adult criminals, becoming crime workers
- Some create small groups (including international ones) and start making illicit profits
- Some become **ethical hackers**, even good ones



Some “testing” tools

- **BurpSuite** – for Web
- **John the Ripper** – for password cracking
- **Metasploit** – complete testing platform
- **Nmap** – historical tool for network and system analyses
- **OpenVas** – for vulnerabilities of networks, systems and passwords
- **Wireshark** – the best tool for network traffic analysis



Cyber threat actors and motivations



[96%]

[4%]

Nation State Actors

Advanced Persistent Threats

Criminals

Professionals

Specialized companies

Ideology

Hacktivists

Terrorists

Antagonists

Lamer

Script kiddies

Pathology



Evolution of technical motivations

Curiosity

Challenge

Ideology

Vandalism

Revenge

Illicit profits

Data acquisition for profit

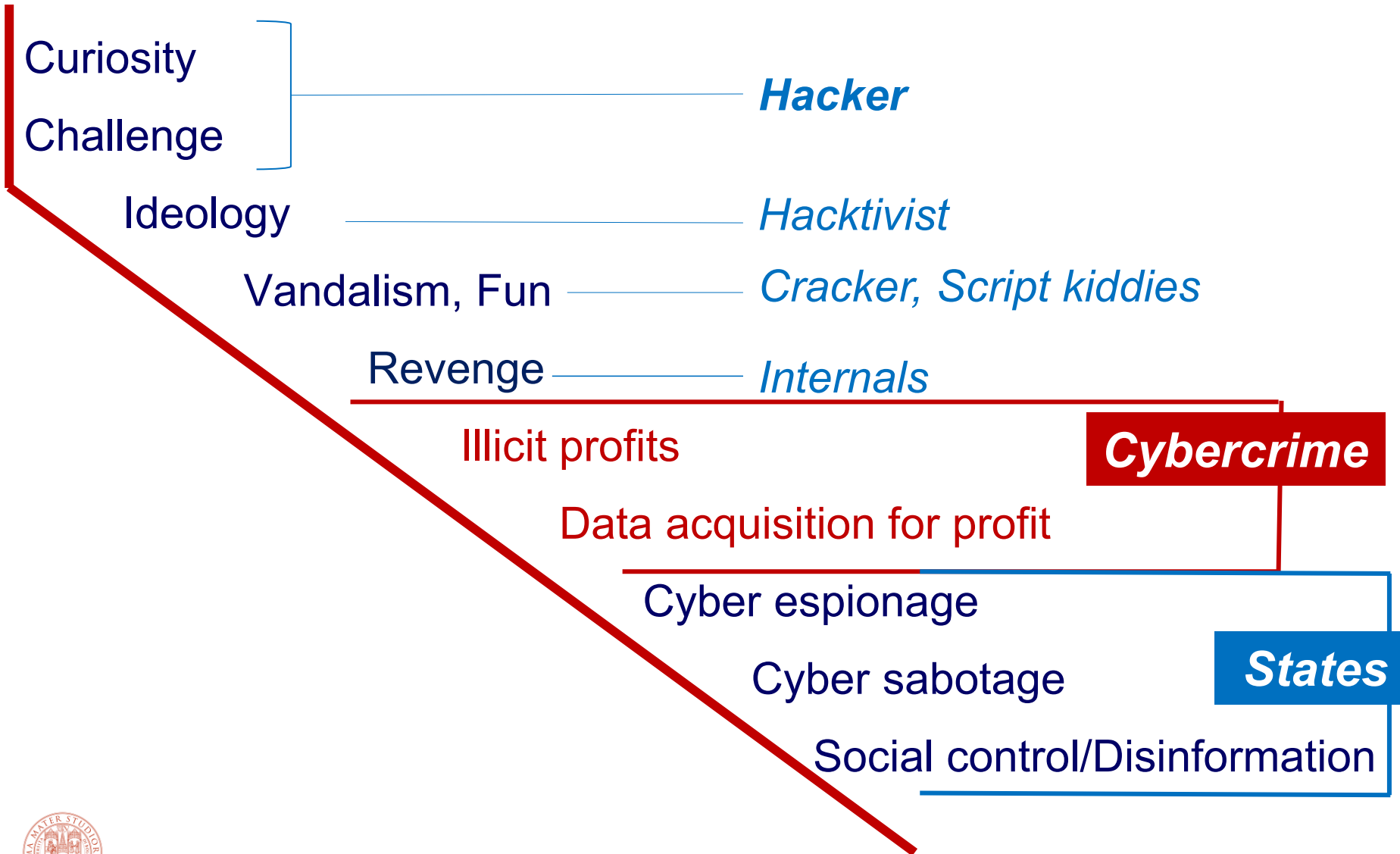
Cyber espionage

Cyber sabotage

Social control/Disinformation



Evolution of technical motivations



Nation State Actors



Cyber threat actors and motivations



Nation State Actors

[96%]

Defence

Intelligence

Law enforcements

Advanced Persistent Threats

Criminals

Professionals

Specialized companies



Nation State actor

- They tend to hire the most competent people
- They have budgets, information and any sort of tools
- They have the Law on their side
- They have to achieve a clear goal, and don't/cannot stop in front of neither technological nor human obstacles
- **It is just a matter of time!**

Do they represent a threat for our company?

Although they represent the top threat, if a company does not belong to *specific categories of interest* for a State, they do not represent a likely threat



Opinion of NCSC counterintelligence

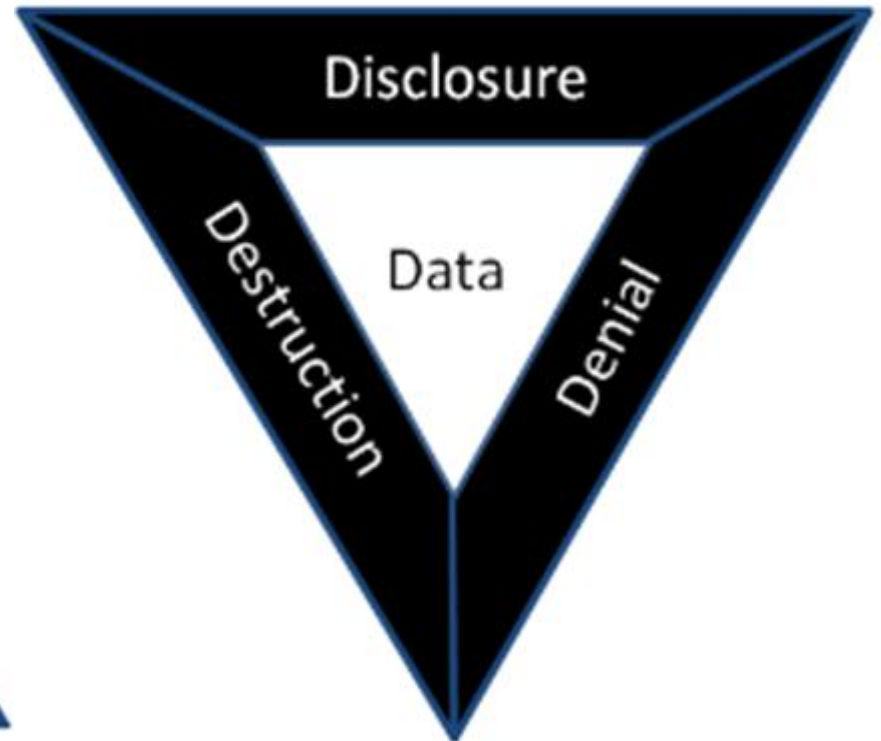
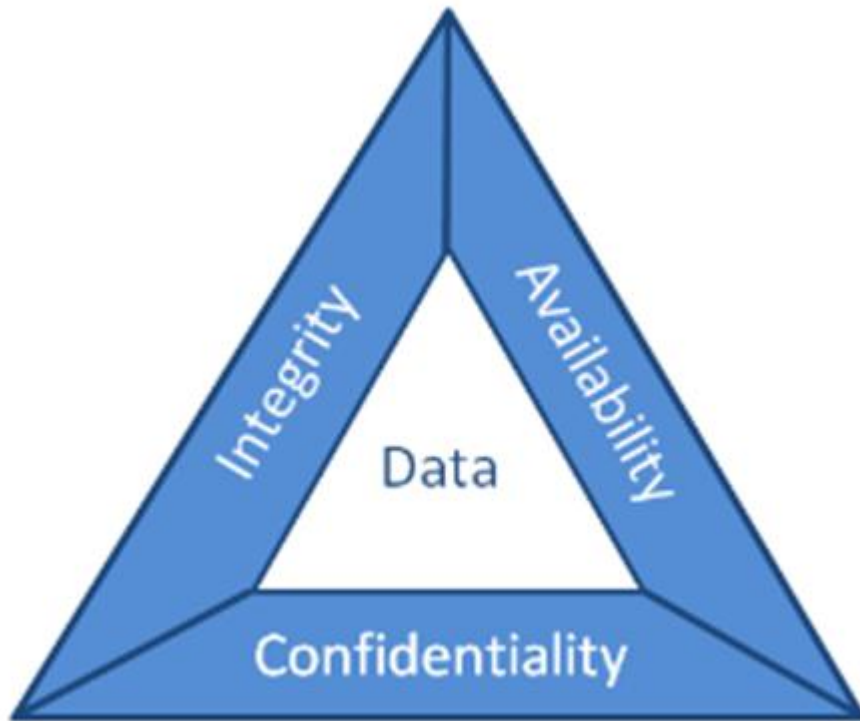


“State and non-state actors use digital technologies to achieve economic, industrial and military advantage, foment social instability, increase control over content in cyberspace, and achieve other strategic goals - ***often faster than our ability to understand the security implications and mitigate potential risks.***”

Their cyber activities present both counterintelligence and security threats”



CIA vs DAD



US: Civil and Military organizations



“Prepare for, respond to, and mitigate the impact of cyberattacks”



https://media.defense.gov/2023/Sep/12/2003299076/-1/-1/1/2023_DOD_Cyber_Strategy_Summary.PDF



Cyber warfare - US

Five pillars of the *Department of Defense Cyber Strategy*:

1. Build and maintain ready forces and capabilities to conduct cyberspace operations
2. Defend the DoD information network, secure DoD data, and mitigate risks to DoD missions
3. Be prepared to defend the U.S. homeland and U.S. vital interests from disruptive or destructive cyber attacks of significant consequence
4. Build and maintain viable cyber options and plan to use those options to control conflict escalation and to shape the conflict environment at all stages
5. Build and maintain robust international alliances and partnerships to deter shared threats and increase international security and stability



Cyber warfare - US

- **Offensive Cyber Operations**
 - **Computer Network Operation**: DoS, cyber attacks, malware → SABOTAGE
 - **Computer Network Operation + PSYOP**: spam, phishing, spear phishing, Web deception, Social network deception
 - **Computer Network Exploitation**: Active ESPIONAGE
 - **SIGINT** (SIGnal INTelligence): signal and communication interception → Passive ESPIONAGE
- **Defensive Cyber Operations**: Defense of data, networks, communications, net-centric operations and any other related systems
- **Department of Defense (DoD) Information Network** operations: **Support to operations** → “Design, build, configure, secure, operate, maintain, and support the communications systems and networks of the Department of Defense in order to ensure the availability, integrity and confidentiality of data as well as the authentication of users and resources and the non-compliance repudiation of operations”



Cyber warfare - China

Main pillars:

1. Targeted **cyber attacks to destroy** the enemy's command and control infrastructure (*Sabotage*)
2. Computer network warfare and Electronic warfare “in order to **dominate the communications spectrum**, preventing the enemy from using its electronic and digital tools” (*Espionage + Sabotage*)
3. **Psychological operations**, denial and deception (*PSYOP*)

“China’s Cyber Warfare Capabilities”, Desmond Ball, Security Challenges
<https://www.jstor.org/stable/26461991>

“Cyber Weapons Gap. The Assessment of the China’s Cyber Warfare Capabilities and Its Consequences for Potential Conflict over Taiwan”, Andrzej Kozłowski



Cyber warfare - Russia

An integrated system for:

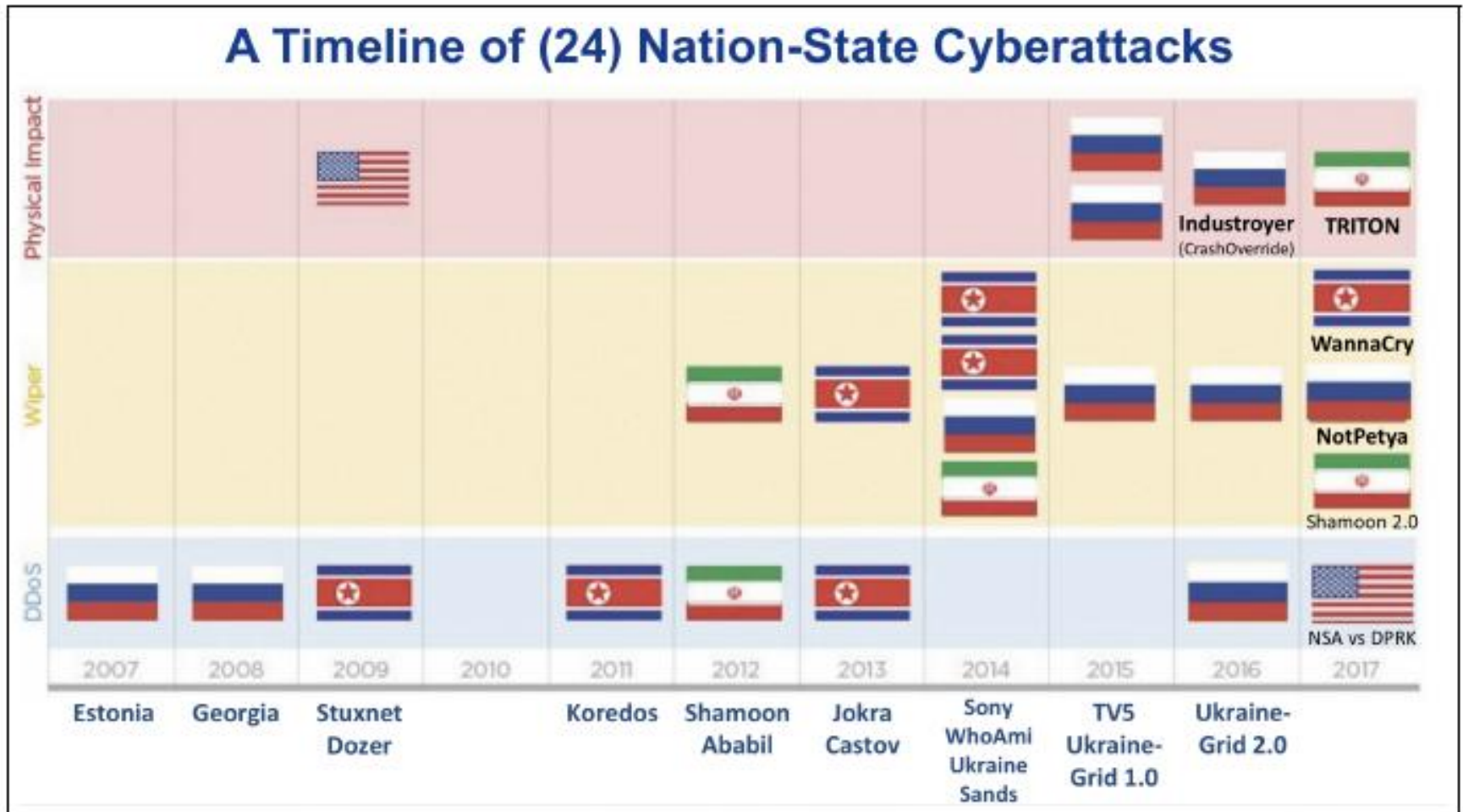
- 1) **establishing control** over computer and information resources, and over the networks and communication systems of enemy states
- 2) developing cyber and information weapon for the **destruction** of computer networks, software applications and services of adversaries
- 3) using of Electric Warfare for **interception** and corruption of communications and modification of transmitted data
- 4) **acquisition of intelligence** and counter-intelligence information
- 5) **disinformation**
- 6) **psychological** pressure on the enemy states

“Putin’s Asymmetric assault on Democracy in Russia and Europe: Implications for U.S. National Security”, Jan. 2018

<http://www.gpoaccess.gov/congress/index.html>



Nation-State cyberattacks



Updated cyberattacks on government agencies, defense and high tech companies; economic crimes with losses of more than a million dollars:
<https://www.csis.org/programs/strategic-technologies-program/significant-cyber-incidents>



Disruptive (*first time*) events

- **'90** – from *hackers* to *vandals*
- **'00** – from *vandals* to *cybercriminals*
- **2007** – Estonia (*against a Nation*)
- **2010** – Stuxnet (*cyber weapon against a physical air-gap nuclear plant*)
- **2012** – Shamoon, BlackEnergy (*against power plants*)
- **2016** – DYN attack (*massive DoS attacks through IoT devices*)
- **2016** – US presidential elections (*political use of cyber influence*)
- **2017** – WannaCry (*world scale extortion*)
- **2017** – NotPetya (*sabotage against a nation with world side effects*)
- **2020** – SolarWinds (*espionage through software update supply chain*)
- **2021** – MS Exchange (*large scale espionage becoming sabotage*)



Advanced Persistent Threats



Cyber threat actors and motivations



[96%]

Nation State Actors

Advanced Persistent Threats

Criminals

Professionals

Specialized companies



Advanced Persistent Threat (APT)

- A sophisticated, systematic cyber-attack that continues for an extended period of time, orchestrated by a group of **skilled actors**, very often collaborating with or sponsored by Nations
- They have sophisticated levels of expertise and significant **resources** (*competence, time, money*). They can use different attack vectors (e.g., cyber, physical, human and deception) to generate multiple opportunities to achieve their objectives
- APTs are designed to sidestep any security provisions you have in place and cause as much penetration and damage as possible. They may utilize multiple entry points and vectors to gain what they want and could evade detection for months and even year
- The APT pursues its objectives repeatedly over an extended period of time, adapting to a defender's efforts to resist it, and with determination to maintain the level of interaction needed to execute its objectives



APT: NIST SP 800-39 definition

“APT is an adversary that possesses sophisticated levels of expertise ...

Their objectives typically include establishing and extending footholds within the information technology infrastructure of the targeted organizations for purposes of

- 1) exfiltrating information,*
- 2) undermining or impeding critical aspects of a mission, program, or organization,*
- 3) or positioning itself to carry out these objectives in the future.”*

An APT is a threat actor operating in cyberspace as a **nation-state actor, state-sponsored actor, hacker-for-hire, or organized cybercriminal group**. What remains constant across APTs is that these threat actors have both the capabilities and resources to conduct highly targeted attacks over long periods of time



Advanced Persistent Threat (APT) – Groups

China									
Common Name	CrowdStrike	IRL	Kaspersky	Dell Secure Works	Mandiant	FireEye	Symantec	iSight	Cisco (VRT/Sourcefire)
Comment Crew	Comment Panda	PLA Unit 61398		TG-8223	APT 1			BrownFox	Group 3
APT 2	Putter Panda	PLA Unit 61486		TG-6952	APT 2				Group 36
UPS	Gothic Panda			TG-0110	APT 3		Buckeye	UPS Team	Group 6
IXESHE	Numbered Panda			TG-2754 (tentative)	APT 12	BeeBus		Calc Team	Group 22
APT 16					APT 16				
Hidden Lynx	Aurora Panda				APT 17	Deputy Dog	Hidden Lynx	Tailgater Team	Group 8
Wekby	Dynamite Panda	PLA Navy		TG-0416	APT 18				
Axiom					APT 17			Tailgater Team	Group 72
Winnti Group	Wicked Panda								
Shell Crew	Deep Panda		WebMasters		APT 19	KungFu Kittens			Group 13
Naikon	Lotus Panda	PLA Unit 78020	Naikon		APT 30				
PLATINUM									
Lotus Blossom			Spring Dragon						
APT 6					APT 6				
Hurricane Panda	Hurricane Panda						Black Vine	TEMP.Avengers	
Emissary Panda	Emissary Panda			Bronze Union, TG-3	APT 27			TEMP.Hippo	Group 35
Stone Panda	Stone Panda				APT 10			MenuPass Team	
Nightshade Panda	Nightshade Panda				APT 9				
APT 26					APT 26			Hippo Team	
Goblin Panda	Goblin Panda		Cycldek						
Night Dragon	Night Dragon								
Mirage	Vixen Panda	Ke3Chang		GREF	APT 15	Playful Dragon		Social Network Team	



In this world, boundaries are never well defined



Nation State Actors

Professionals (for hire)

Specialized companies

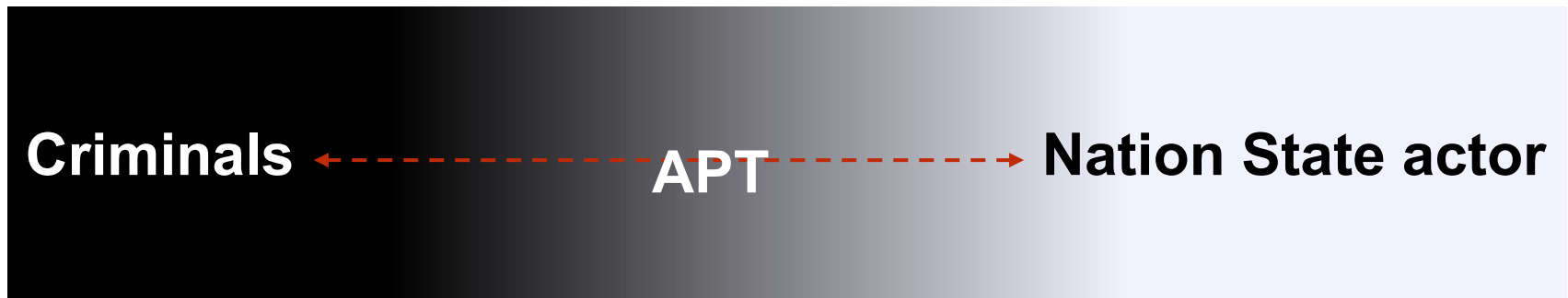
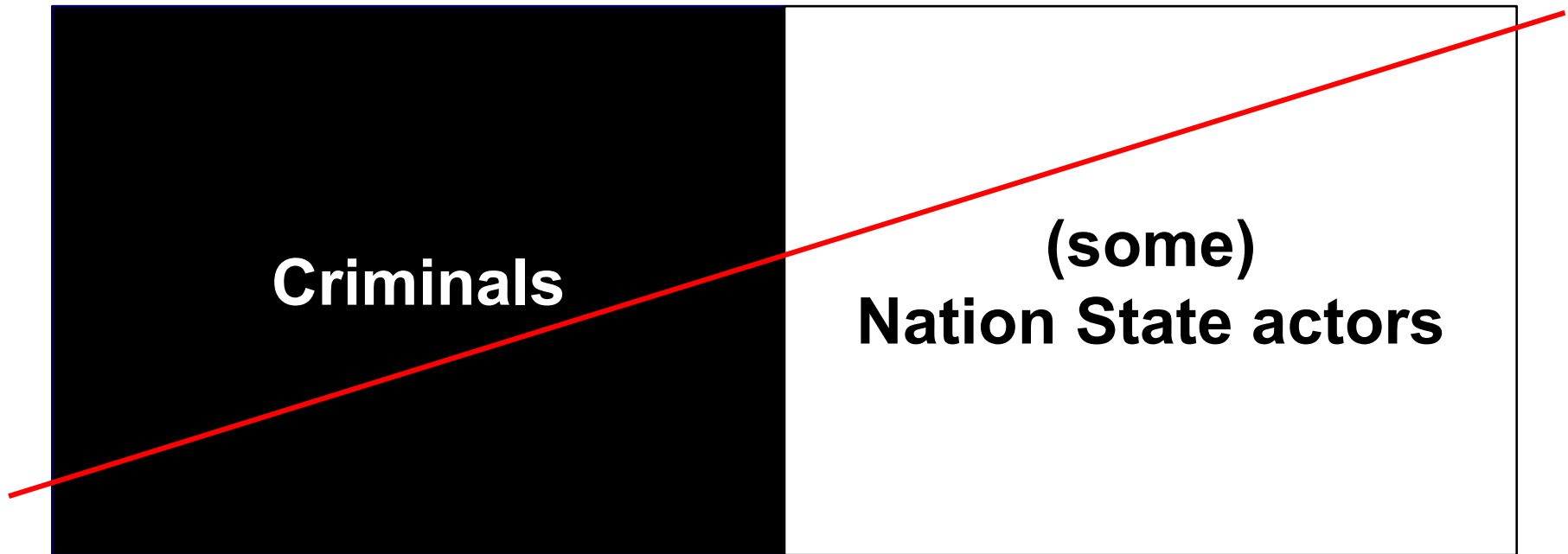
APT

Organized
Criminals

An APT is a threat actor operating in cyberspace as a **nation-state actor, state-sponsored actor, hacker-for-hire, or organized cybercriminal group**. Common characteristics: APTs have the capabilities and resources to conduct highly targeted attacks over long periods of time



In this world, boundaries are never well defined



Some famous examples of attributions to Russia/China

- **Influence on US Presidential elections (2016)**

<https://www.nytimes.com/2016/12/13/us/politics/russia-hack-election-dnc.html>

- **NotPetya sabotage against Ucraina (2017)**

<https://www.ncsc.gov.uk/news/russian-military-almost-certainly-responsible-destructive-2017-cyber-attack>

- **SolarWinds against US agencies and ministries (2020)**

<https://go.recordedfuture.com/hubfs/reports/pov-2020-1230.pdf>

<https://www.zdnet.com/article/us-government-formally-blames-russia-for-solarwinds-hack/>

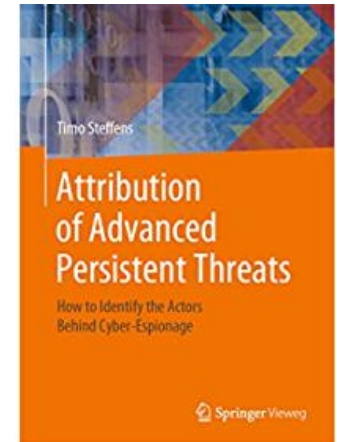
<https://www.cyberscoop.com/fireeye-russia-solarwinds-kevin-mandia-postcard/>

- **Attack to Microsoft Exchange (2021): *Attribution to China***



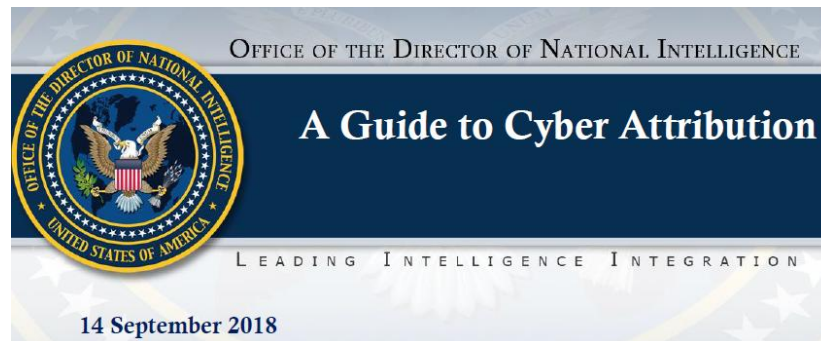
The attribution problem (1)

- Companies and public authorities do not always have enough knowledge of these actors to prioritize the threats emanating from them. This lack of information is reflected in the **issue of attribution**
- It is highly difficult to attribute an attack if you do not have the necessary resources and expertise to adequately recognize it
- Knowing who is responsible or attributing responsibilities to a person or a group for a cybersecurity incident **is still a very daunting task and often a worthless exercise**



The attribution problem (2)

- Although attributing responsibilities to a person or a group for a cybersecurity incident is still a very daunting task, from a *threat intelligence* perspective, it is essential to:
 - classify behaviors
 - understand the dynamics
 - understand *modus operandi* used by adversaries
- This analysis helps defenders to look for specific tracks and try to anticipate the next adversarial action



Cyber criminals



Professional cyber threat actors



Nation State Actors

[96%]

Advanced Persistent Threats

Criminals

Actors

Providers

Professionals

Specialized companies



Cyber criminals are criminals



Cyber criminals

Criminals



They represent the most likely cyber threat for the large majority of organizations



Cybercrime is a mature industry

1. Vertical criminal specialization

2. Markets for exchange: *de facto* open virtual spaces

a) **Criminal marketplace:** (similar to e-commerce sites)

- Sales areas / purchase spaces
- Advertisements and offers
- Cryptocurrency payments
- Trust on (criminal) sellers based on continuous feedbacks

b) **Hidden forum:** closed circles based on invitation (ethnic groups, ideologies, groups of interest, ...)

3. Crime as a Service

- Developers, administrators and moderators of black-market platforms

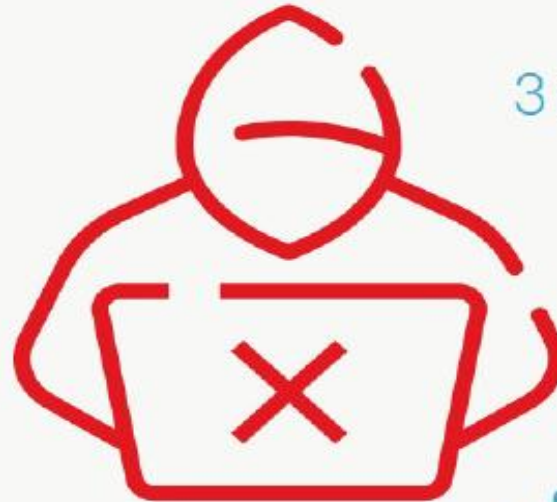


Vertical criminal specializations

1 Services



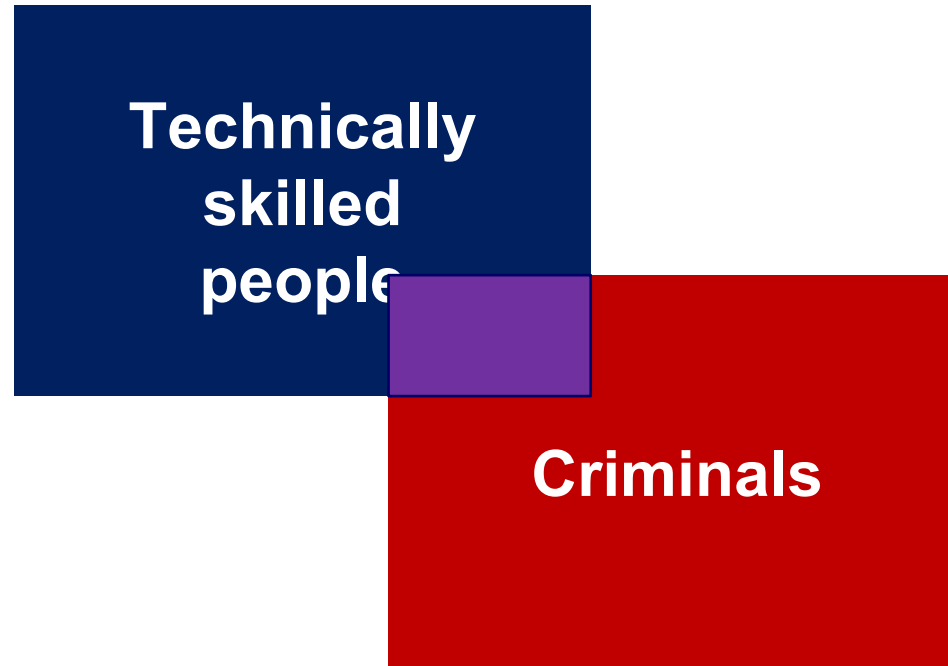
2 Distribution



3 Monetization



Besides motivations, there are two types of threat actors



Types of cyber criminals

1) Actors

2) Facilitators

- Login/password
- Software vulnerabilities
- Exploit, 0-day
- Money laundering
- Administrators and moderators of black markets
- Developers of “integrated” platforms

2) Third parties

- Moderators of Dark markets
- Escrow of the Dark Web
- CaaS platforms

